VANGUARD ENTERPRISE SECURITY & AI GOVERNANCE SOP

Policy Document: POL-SEC-2026-v4.2 | Classification: RESTRICTED INTERNAL
Effective Date: February 1, 2026 | Mandatory Annual Compliance Audit

1. PURPOSE, SCOPE, AND GOVERNING STANDARDS

1.1 Purpose: This Standard Operating Procedure establishes corporate requirements for securing enterprise data, governing generative AI usage, and ensuring regulatory compliance across all corporate business units.
1.2 Applicable Standards: Vanguard Systems Corp complies with ISO/IEC 27001:2022, SOC 2 Type II Trust Services Criteria, NIST Cybersecurity Framework 2.0, and GDPR / CCPA data privacy statutes.
1.3 Applicability: This policy applies to all full-time employees, contractors, third-party vendors, and system administrators.

2. IDENTITY MANAGEMENT, ZERO TRUST & AUTHENTICATION

2.1 Multi-Factor Authentication (MFA): Phishing-resistant FIDO2 hardware security keys or authorized mobile authenticator apps are mandatory for accessing all enterprise systems, email, and VPN tunnels. SMS-based 2FA is strictly prohibited.
2.2 Least Privilege Principle: Access to production databases and customer data repositories is granted on a Just-In-Time (JIT) basis with automatic revocation after four (4) hours. Quarterly access reviews are mandatory for all Department Heads.
2.3 Password Policy: System accounts require minimum 16-character passphrases, automated 90-day compromise scanning, and immediate invalidation upon employee separation.

3. GENERATIVE AI AND LARGE LANGUAGE MODEL GOVERNANCE

3.1 Prohibition of Public AI Tools: Employees are strictly prohibited from submitting proprietary source code, Customer PII, unreleased financial data, or legal drafts into public AI chat interfaces (e.g., consumer ChatGPT, Claude, Gemini).
3.2 Approved Enterprise RAG Pipelines: Employees may exclusively utilize approved internal RAG platforms that enforce Zero Data Retention (ZDR) APIs, local vector embedding models, and encrypted TLS 1.3 data transmission.
3.3 Model Output Verification: Any AI-generated code, legal analysis, or regulatory report must undergo mandatory human review by a certified domain professional prior to external release or production deployment.

4. INCIDENT RESPONSE, CLASSIFICATION, AND NOTIFICATION SLAS

4.1 Severity Classification:

- P1 Critical: Confirmed unauthorized exfiltration of Customer PII, ransomware deployment, or complete production outage.
- P2 High: Suspected unauthorized credential compromise or malicious malware detection on corporate endpoints.
- P3 Medium: Isolated policy violation or unauthorized software installation.

4.2 Response Timelines:

- P1 Critical Incidents require Incident Response Team activation within fifteen (15) minutes of alert generation.
- Customer and Regulatory Notification SLA: Executive notification to affected customers and supervisory authorities must occur within seventy-two (72) hours of confirmed breach, in accordance with GDPR Article 33.

4.3 Post-Mortem Requirement: A formal root-cause analysis (RCA) and remediation plan must be submitted to the Chief Information Security Officer (CISO) within five (5) business days of incident resolution.

5. AUDIT CADENCE, PENALTIES, AND DISCIPLINARY ACTIONS

5.1 Audit Cadence: Third-party independent SOC 2 Type II audit occurs annually in October. Bi-annual external penetration testing is conducted across all external-facing cloud IP ranges.

5.2 Non-Compliance Sanctions: Failure to adhere to identity or AI governance protocols constitutes a security violation subject to mandatory retraining, formal written reprimand, or termination of employment for willful gross negligence.